



IGNITE

— EXECUTIVE SECURITY BRIEFING

The compliance gate for code entering **our GitHub organization.**

A unified, automated control point that stands between every uploaded project and production — enforcing secrets hygiene, secure-coding standards, supply-chain integrity, and AI-era risk controls before a single line ships.

20+

Integrated security & compliance engines

6

Sequential gate phases, every upload

0

Silent bypasses of a blocking finding

100%

Of onboarded projects pass through the gate

Every new codebase is a new blast radius — until it passes the gate.

Code brought into our organization — by engineers, contractors, or increasingly by AI coding assistants — is the single largest source of unmanaged risk in the software supply chain. Ignite closes that gap with one automated, non-negotiable checkpoint applied to every onboarded project.



Breach exposure, cut at the source

Leaked credentials, vulnerable dependencies, and insecure patterns are caught before code ever reaches a repository a threat actor can reach.



Audit-ready by default

Every decision — pass, block, or human-justified override — is attributed, timestamped, and logged. Evidence for SOC 2, ISO 27001, and EU AI Act reviews is a byproduct, not a project.



Security that doesn't slow delivery

Fully automated and parallelized — engineering teams get a pass/fail verdict in minutes, with a self-service fix loop instead of a ticket queue.

One pipeline, six gates, zero silent exceptions.

Every upload flows through independent checkpoints. A single failed gate halts the run
— nothing reaches GitHub without every phase clearing, or a justified, attributed override.



● BLOCKING = MUST FIX OR OVERRIDE

● ADVISORY = VISIBLE, NEVER GATES

● PASS = PROVISIONED AUTOMATICALLY

Static analysis & secret detection.

The first line of code-level defense — every one of these engines is a category leader, not an in-house heuristic.



Semgrep SEMGREP, INC.

OWASP-aligned static-analysis engine covering 30+ languages; the default SAST layer for security-mature engineering orgs and CI/CD pipelines industry-wide.



CodeQL GITHUB / MICROSOFT

Cross-file, cross-function taint-tracking engine powering GitHub Advanced Security — catches injection and IDOR chains that single-file scanners miss entirely.



Bearer BEARER.COM

Purpose-built PII / GDPR data-flow analysis — traces sensitive data from source to sink for privacy-risk and regulatory-exposure reporting.



Gitleaks OPEN-SOURCE STANDARD

The most widely deployed open-source secret scanner — entropy and regex detection for API keys, tokens, and credentials before a commit ever leaves staging.



picklescan AI-ERA ADDITION

Opcodes-level scan of ML model artifacts (.pkl/.pt/.bin/.ckpt) for malicious deserialization payloads — a risk vector standard SAST tools were never built to see, and one that's grown directly out of AI-assisted development.

Supply chain, container & infrastructure security.

The tooling that closed the SolarWinds-and Log4j-class gap: what's inside the artifact, and can its origin be trusted.



Trivy AQUA SECURITY • CNCF

The de-facto standard for container image, IaC misconfiguration, and dependency vulnerability scanning — a graduated CNCF project used across the cloud-native ecosystem.



Checkov PALO ALTO NETWORKS (PRISMA CLOUD)

Policy-as-code IaC compliance across Terraform, CloudFormation, and Kubernetes manifests, backed by an enterprise cloud-security vendor's rule research.



Syft & Cosign ANCHORE / SIGSTORE, LINUX FOUNDATION

CycloneDX SBOM generation plus Sigstore-backed signature verification — the industry reference implementation for artifact provenance and SLSA-aligned supply-chain integrity.



GuardDog DATADOG SECURITY RESEARCH

Heuristic inspection of npm/PyPI packages for malicious behavior before they're trusted — built and maintained by a leading commercial security-research team.



hadolint OPEN-SOURCE STANDARD

Dockerfile best-practice linting against Docker's own authoring guidelines — unpinned base images, missing non-root USER, and other container hygiene defects, caught pre-build.

AI-era risk & compliance governance.

Risk vectors that didn't exist five years ago — purpose-built for a world where a meaningful share of committed code is AI-generated or AI-assisted.



Package-Hallucination Guard IGNITE, BUILT-IN

Live registry checks against npm / PyPI / crates.io catch "slopsquatting" — an LLM inventing a plausible package name an attacker has already registered with malware.



oasdiff OPEN-SOURCE STANDARD

Diffs every API spec against its prior committed revision to catch breaking changes and shadow endpoints — the kind of silent contract drift AI-assisted refactors introduce fastest.



Spectral STOPLIGHT

OpenAPI / AsyncAPI governance linting against organizational schema standards — the industry-standard API-design rule engine.



Compliance & Posture Engine IGNITE, ON SEMGREP

Classifies SSO / RBAC / audit-logging / encryption posture, plus EU AI Act Art. 5, 12, 13 & 50 signals — always advisory, always human-reviewed before action.



CodeQL Cross-File Analysis GITHUB / MICROSOFT

The security-extended query suite, applied whole-project — closing the exact gap single-file SAST leaves open when a tainted-data chain spans a controller, a service layer, and a template.

Static analysis (SAST)

✓ CodeQL

✓ CodeQL + Semgrep + Bearer

IaC & container misconfiguration

– Not covered

✓ Trivy, Checkov, hadolint

SBOM & signature verification

– Dependency graph only

✓ Syft SBOM + Cosign signing

PII / GDPR data-flow analysis

– Not covered

✓ Bearer

Malicious ML model artifacts

– Not covered

✓ picklescan

AI package-hallucination check

– Not covered

No engine in this stack is an unproven internal script — each is either the recognized leader in its category (Aqua Security, GitHub, Datadog, Sigstore/Linux Foundation) or a purpose-built Ignite control for a risk class those vendors don't yet cover. The value isn't any single scanner; it's that all of them run every time, on every project, with no exceptions that aren't logged.



Consistent enforcement

One gate, zero exceptions for who's uploading — engineer, contractor, or agent.



Regulator-ready evidence

Attributed overrides and full scan history, on demand — no scramble before an audit.



Board-level assurance

A single control the executive team can point to, backed by industry-standard tooling.